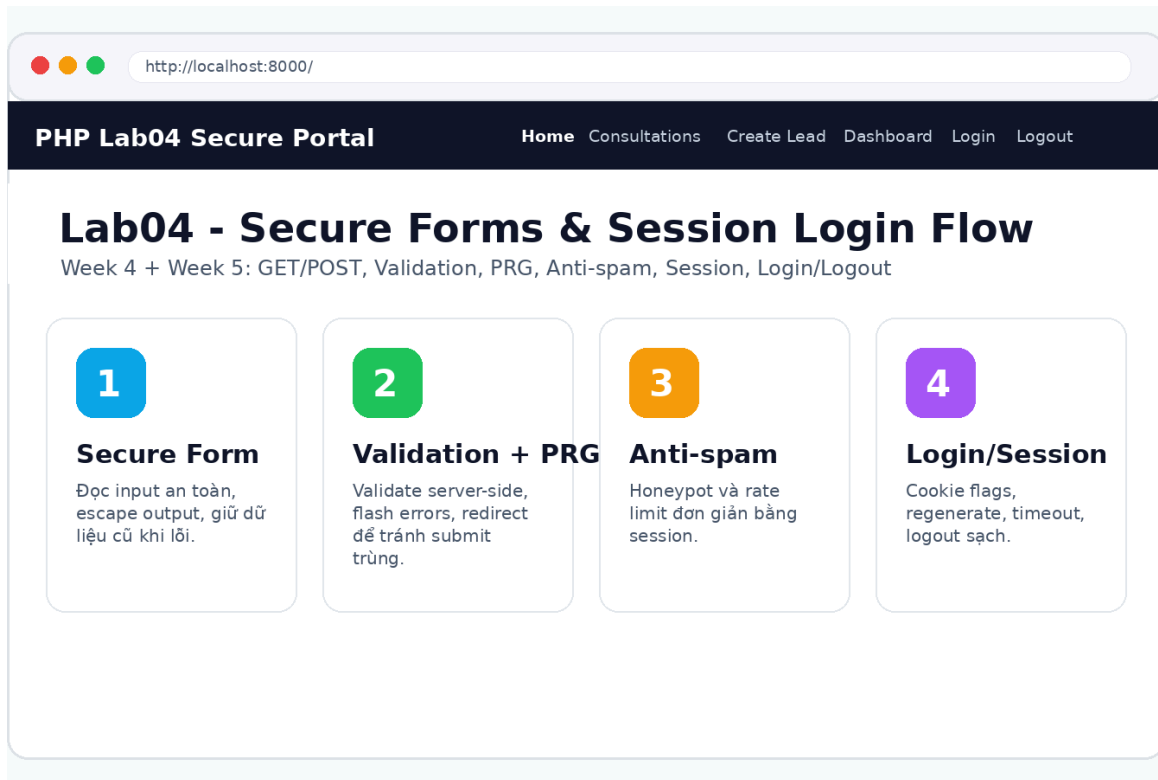


Lab04 - PHP Secure Forms, PRG, Anti-spam & Session Login Flow



Hình 1. Tổng quan các màn hình và kỹ thuật chính của Lab04

Tên bài toán: Student Consultation & Secure Login Portal

1) Mục tiêu bài Lab

- Triển khai form đăng ký từ vẫn có đọc input an toàn bằng POST, trim dữ liệu và escape output khi hiển thị.
- Xây dựng validation server-side: required, email format, phone pattern, length và in-list validation.
- Hiển thị lỗi đúng field, giữ lại dữ liệu cũ khi submit sai bằng flash old/errors.
- Áp dụng PRG (Post/Redirect/Get) để tránh submit trùng khi refresh sau POST.
- Tạo lớp anti-spam cơ bản bằng honeypot field và rate limit theo session.
- Cấu hình session cookie flags cơ bản: HttpOnly, SameSite, Secure theo môi trường.
- Triển khai login/logout flow đúng ở mức nền tảng: validate input, verify password, session_regenerate_id(true), redirect, flash message.
- Thực hiện timeout phiên, kiểm tra trạng thái đăng nhập và logout sạch.
- Giải thích rủi ro của remember me và không lưu password trong cookie.
- Test được các tình huống lỗi thực tế: dữ liệu bẩn, submit trùng, spam, session fixation/hijack mức cơ bản, flash/redirect sai.

2) Các bước tiến hành

- Chuẩn bị project từ Lab03 hoặc tạo project mới có Front Controller và Router.
- Tạo cấu trúc thư mục app/public/views/storage rõ ràng.
- Cấu hình Composer PSR-4 autoload.

- Cấu hình session cookie params trước session_start().
- Tạo helper: h(), redirect(), flash_set(), flash_get(), old(), errors().
- Khai báo route cho Home, Consultation, Auth, Dashboard.
- Tạo layout, CSS và các view HTML.
- Tạo form đăng ký tư vấn và xử lý POST /consultations.
- Thêm validation server-side, PRG, honeypot, rate limit và lưu JSON.
- Tạo login/logout flow có regenerate, flash và timeout.
- Test bằng browser, DevTools, curl/Postman.
- Commit code, đưa lên GitHub và nộp bài.

3) Mô tả bài toán

Bối cảnh: Một trung tâm đào tạo cần xây dựng một cổng web nhỏ để nhận lead tư vấn khóa học và cho nhân viên đăng nhập xem dashboard. Ở các bài trước, sinh viên đã biết tổ chức request qua public/index.php, Router và Controller. Tuy nhiên, nếu chỉ viết form “nhập rồi gửi” thì hệ thống dễ gặp lỗi thực tế: lead bị thất thoát, dữ liệu bẩn, submit trùng, spam, login/session rồi, logout không sạch và flash/redirect sai trạng thái.

Mục tiêu của Lab04: chuyển từ tư duy “form chạy được” sang tư duy “form/session đủ an toàn và đủ rõ trạng thái cho nghiệp vụ”.

Sơ đồ luồng Lab04: Form + PRG + Session



Luồng login/session



Ghi nhớ bảo mật: Input từ user luôn không đáng tin; server phải validate. Cookie phiên cần HttpOnly/SameSite/Secure. Logout phải xóa trạng thái sạch. Remember me không được lưu password.

Hình 2. Luồng xử lý tổng hợp của Lab04

4) Yêu cầu chức năng

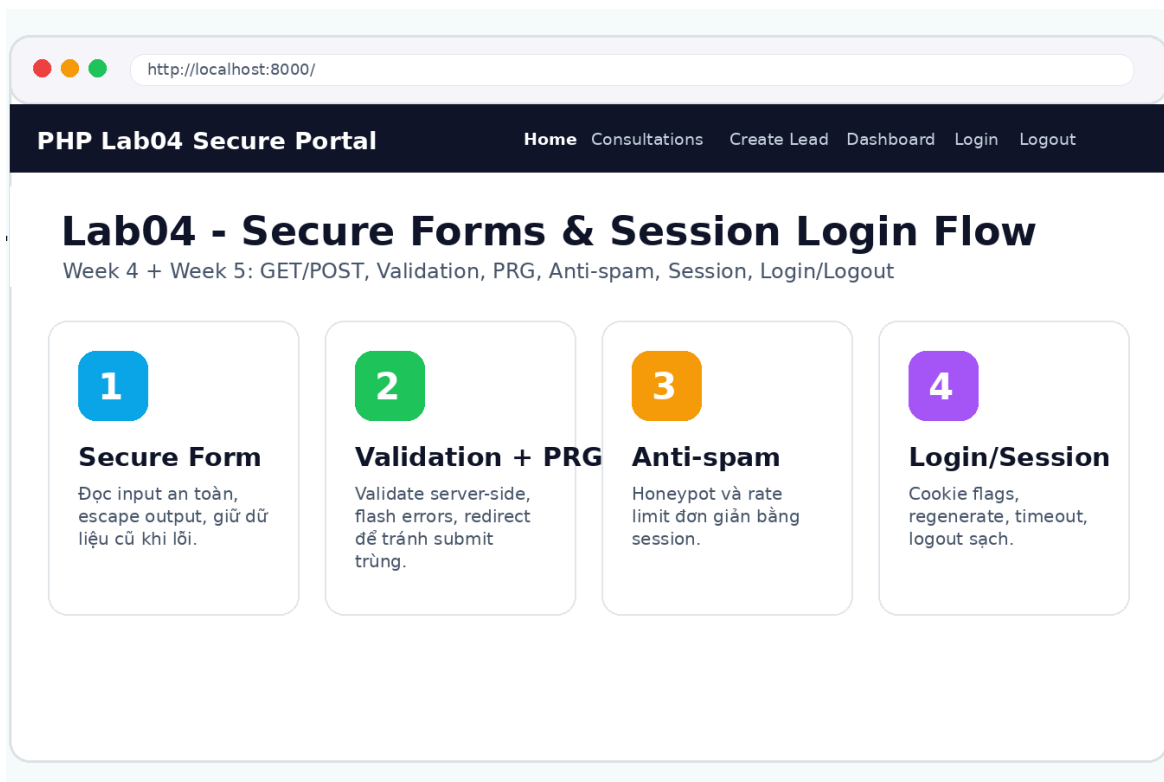
Method	URL	Controller@Action	Response / Ý nghĩa
GET	/	HomeController@index	HTML trang tổng quan Lab04
GET	/consultations	ConsultationController@index	HTML danh sách lead + flash success/error
GET	/consultations/create	ConsultationController@create	HTML form đăng ký tư vấn
POST	/consultations	ConsultationController@store	Validate + anti-spam + lưu JSON + redirect

GET	/login	AuthController@login	HTML form login
POST	/login	AuthController@handleLogin	Validate + verify password + regenerate + redirect
POST	/logout	AuthController@logout	Logout sạch + redirect về login
GET	/dashboard	DashboardController@index	Chỉ cho user đã đăng nhập
GET	/session-demo	DashboardController@sessionDemo	Hiển thị thông tin session phục vụ debug
ANY	URL không tồn tại	Router	404 Not Found
Sai method	Route có tồn tại nhưng method sai	Router	405 Method Not Allowed

Ghi chú: Lab04 dùng POST /logout thay vì GET /logout để tránh logout do click link hoặc crawler. Bài này chưa yêu cầu CSRF token; CSRF sẽ phù hợp hơn ở tuần bảo mật nâng cao.

5) Hình giao diện mong đợi

5.1 Trang tổng quan - GET /



Hình 3. Trang tổng quan Lab04

- Trang này giúp sinh viên thấy các nhóm chức năng chính: Secure Form, Validation + PRG, Anti-spam, Login/Session.
- Các nút điều hướng phải trở đến đúng route trong bảng yêu cầu chức năng.

5.2 Form đăng ký tư vấn - GET /consultations/create

The screenshot shows a web browser window with the address bar displaying `http://localhost:8000/consultations/create`. The page header is 'PHP Lab04 Secure Portal' with navigation links: Home, Consultations, **Create Lead**, Dashboard, Login, and Logout. The main heading is 'Form đăng ký tư vấn' with a subtitle: 'Submit đến POST /consultations. Có field honeypot ẩn và validate server-side.'

The form contains the following fields and elements:

- Họ tên** (Last Name): Input field with value 'Nguyễn An'.
- Email**: Input field with value 'student@example.com'.
- Số điện thoại** (Phone Number): Input field with value '0901234567'.
- Khóa học quan tâm** (Interested Course): Input field with value 'Web Development'.
- Nội dung cần tư vấn** (Consultation Content): Text area with value 'Em muốn được tư vấn lộ trình học web.'
- Honeypot field**: A hidden field with the label 'Field ẩn: website (honeypot) - user thật không thấy/không nhập'.
- Buttons**: 'Gửi đăng ký' (Submit) and 'Quay lại' (Back).

Hình 4. Form đăng ký tư vấn hợp lệ

- Form submit đến POST /consultations.
- Field website là honeypot ẩn, user thật không nhìn thấy và không nhập.
- Các field chính: name, email, phone, course, message.

5.3 Trạng thái validation lỗi

http://localhost:8000/consultations/create

PHP Lab04 Secure Portal Home Consultations Create Lead Dashboard Login Logout

Form đăng ký tư vấn - trạng thái lỗi

Vui lòng kiểm tra lại thông tin. Dữ liệu cũ vẫn được giữ để sửa.

Họ tên
A
Họ tên phải có ít nhất 2 ký tự.

Email
abc@
Email không đúng định dạng.

Số điện thoại
abc123
Số điện thoại chỉ gồm số, khoảng trắng, + hoặc -.

Khóa học quan tâm
-- Chọn khóa học --
Vui lòng chọn khóa học hợp lệ.

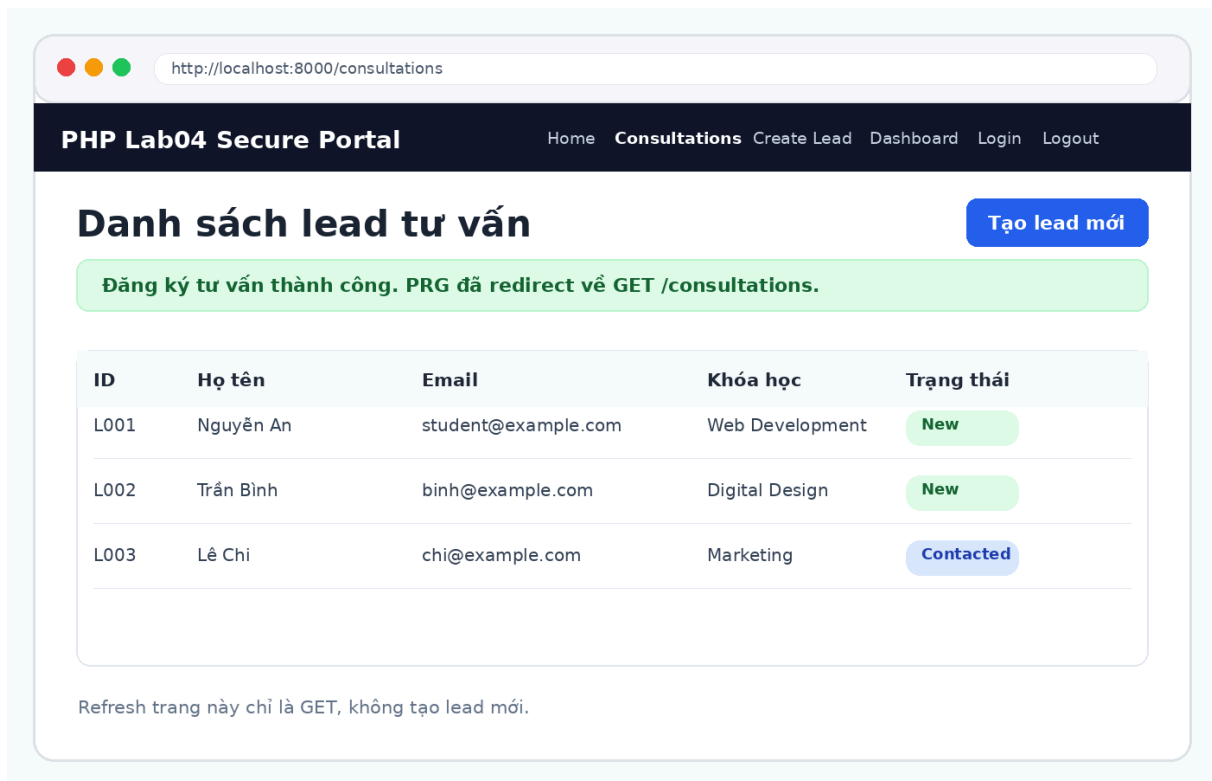
Nội dung cần tư vấn

Sửa và gửi lại

Hình 5. Giao diện hiển thị lỗi cạnh từng field

- Nếu submit sai, hệ thống hiển thị lỗi đúng field.
- Dữ liệu cũ vẫn còn để user sửa, không phải nhập lại toàn bộ.
- Các lỗi được truyền qua flash old/errors sau redirect về form.

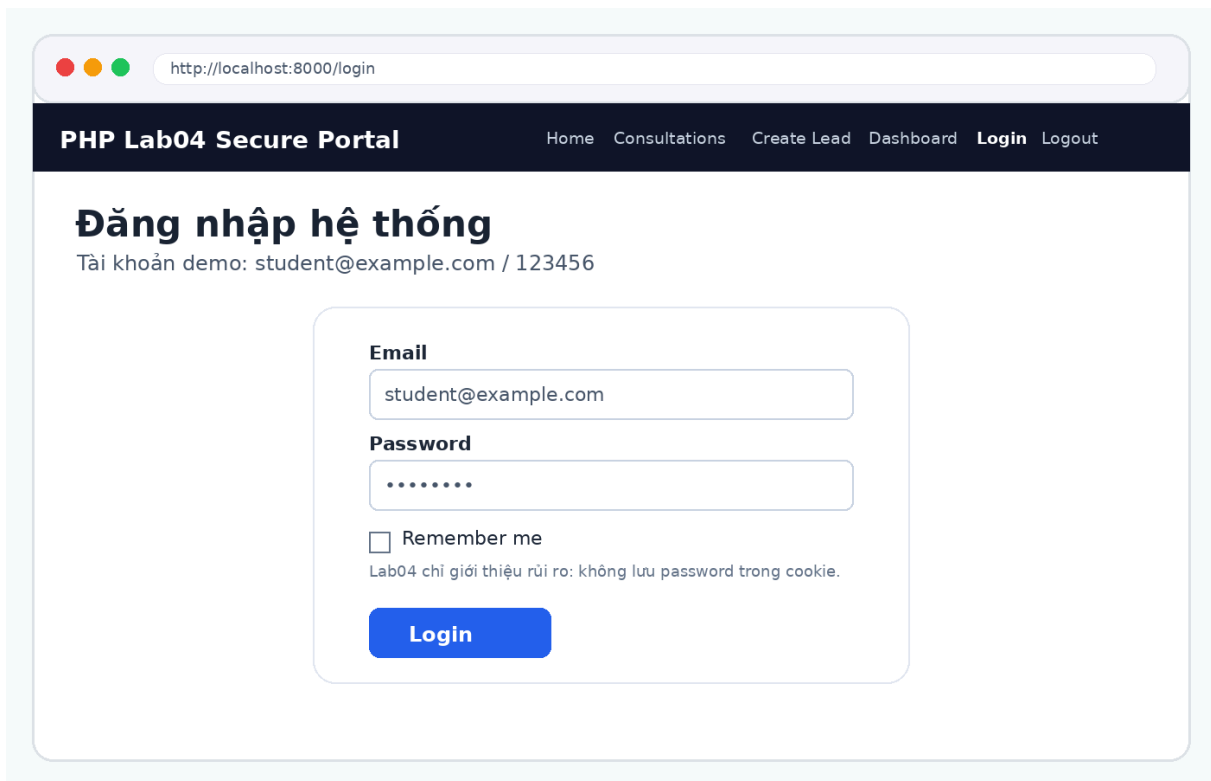
5.4 Submit thành công và danh sách lead - GET /consultations



Hình 6. Danh sách lead sau PRG thành công

- Sau khi POST hợp lệ, controller redirect về GET /consultations.
- Flash success chỉ hiện một lần.
- Refresh trang danh sách không tạo lead trùng.

5.5 Trang login - GET /login



http://localhost:8000/login

PHP Lab04 Secure Portal Home Consultations Create Lead Dashboard **Login** Logout

Đăng nhập hệ thống

Tài khoản demo: student@example.com / 123456

Email

student@example.com

Password

.....

☐ Remember me

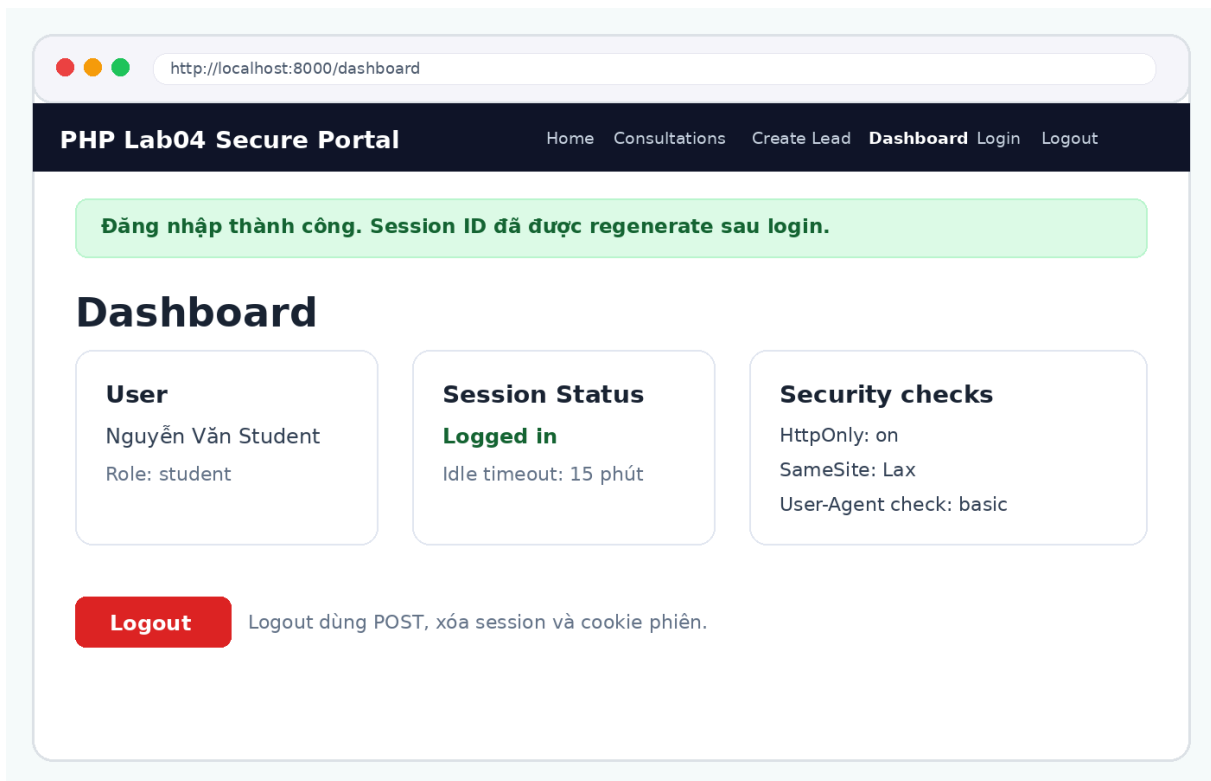
Lab04 chỉ giới thiệu rủi ro: không lưu password trong cookie.

Login

Hình 7. Form login có checkbox remember me để thảo luận rủi ro

- Tài khoản demo: student@example.com / 123456.
- Checkbox remember me không được dùng để lưu password trong cookie.
- Nếu sinh viên muốn nâng cấp remember me, phải dùng token riêng, lưu token hash ở server và có cơ chế thu hồi.

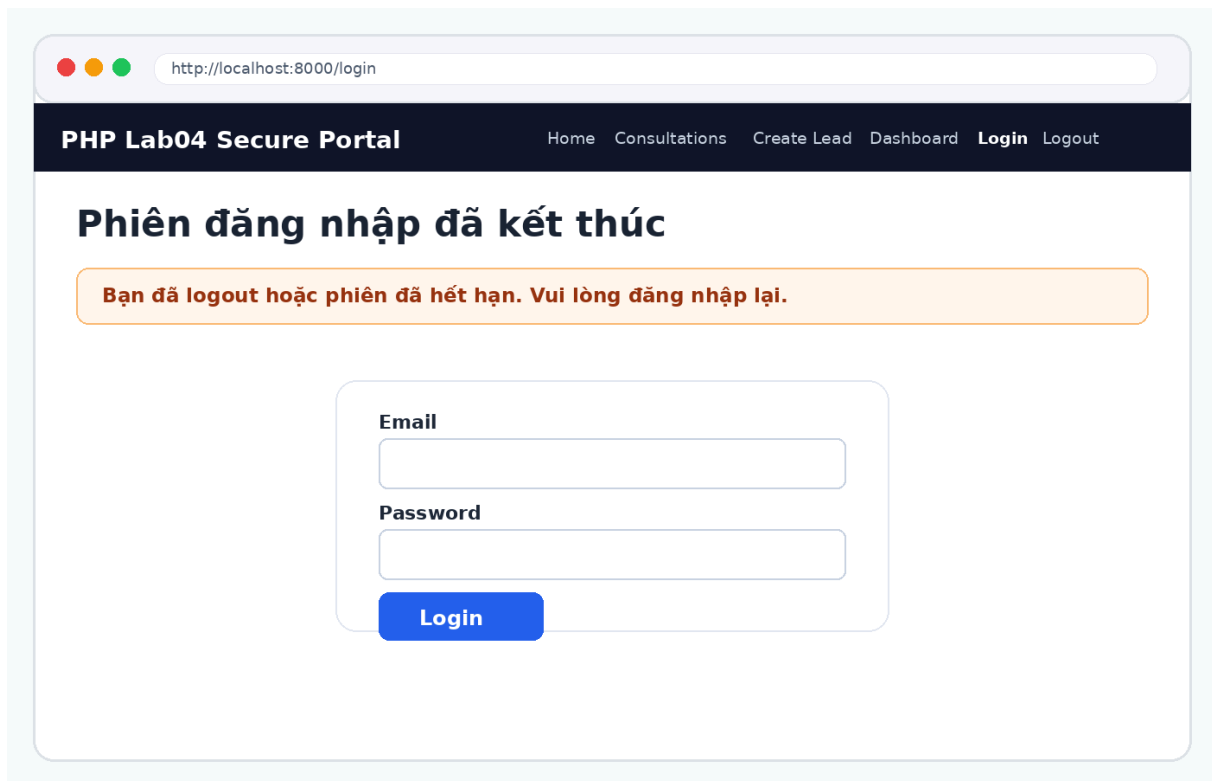
5.6 Dashboard sau đăng nhập - GET /dashboard



Hình 8. Dashboard hiển thị trạng thái session

- Chỉ user đã đăng nhập mới truy cập được.
- Login thành công phải gọi `session_regenerate_id(true)`.
- Dashboard hiển thị các thông tin debug như user, role, login_at, last_activity_at.

5.7 Logout hoặc timeout



Hình 9. Trạng thái sau logout hoặc hết phiên

- Logout phải xóa trạng thái user, destroy session và xóa cookie phiên.
- Timeout phải redirect về login với flash message rõ ràng.
- Không để user bị “kẹt trạng thái” hoặc flash hiện mãi.

6) Cấu trúc project yêu cầu

Cấu trúc thư mục mẫu

lab04-secure-form-session/

```
├── app/
│   ├── Controllers/
│   │   ├── HomeController.php
│   │   ├── ConsultationController.php
│   │   ├── AuthController.php
│   │   └── DashboardController.php
│   ├── Core/
│   │   ├── Router.php
│   │   └── Response.php
│   ├── Support/
│   │   └── helpers.php
│   └── public/
│       ├── index.php
│       ├── assets/
│       │   └── style.css
│       └── storage/
│           └── consultations.json
├── views/
│   ├── layout.php
│   └── home.php
```

```

|   |   | consultations/
|   |   | |   | index.php
|   |   | |   | create.php
|   |   | |   |
|   |   | |   | auth/
|   |   | |   | |   | login.php
|   |   | |   | |   |
|   |   | |   | |   | dashboard.php
|   |   | |   | |   |
|   |   | |   | |   | errors/
|   |   | |   | |   | |   | 404.php
|   |   | |   | |   | |   | 405.php
|   |   | |   | |   |
|   |   | |   | |   | composer.json

```

Ghi chú: Có thể copy project Lab03 rồi đổi tên sang lab04-secure-form-session để tiết kiệm thời gian. Không dùng database trong Lab04 để sinh viên tập trung vào request, form, session và flow.

7) Hướng dẫn Step by Step

Bước 1 - Tạo project và khởi tạo Git

```

mkdir lab04-secure-form-session
cd lab04-secure-form-session
mkdir -p app/Controllers app/Core app/Support public/assets storage views/consultations views/auth views/errors
touch storage/consultations.json
echo "[]" > storage/consultations.json
git init

```

- Mục tiêu của bước này là tạo khung project giống Lab03 nhưng có thêm storage và views cho consultation/auth.
- File consultations.json lưu dữ liệu lead mẫu để không cần database.

Bước 2 - Tạo composer.json và bật PSR-4 autoload

composer.json

```

{
  "autoload": {
    "psr-4": {
      "App\\": "app/"
    },
    "files": [
      "app/Support/helpers.php"
    ]
  }
}

```

Lệnh chạy

```
composer dump-autoload
```

Bước 3 - Tạo public/index.php làm Front Controller và cấu hình session

```

<?php

require __DIR__ . '/../vendor/autoload.php';

use App\Core\Router;
use App\Controllers\HomeController;

```

```

use App\Controllers\ConsultationController;
use App\Controllers\AuthController;
use App\Controllers\DashboardController;

$isHttps = (!empty($_SERVER['HTTPS']) && $_SERVER['HTTPS'] !== 'off');

session_name('LAB04SESSID');
session_set_cookie_params([
    'lifetime' => 0,
    'path' => '/',
    'domain' => '',
    'secure' => $isHttps,    // local HTTP: false, production HTTPS: true
    'httponly' => true,
    'samesite' => 'Lax',
]);
session_start();

check_session_timeout();
check_session_context();

$router = new Router();

$router->get('/', [HomeController::class, 'index']);
$router->get('/consultations', [ConsultationController::class, 'index']);
$router->get('/consultations/create', [ConsultationController::class, 'create']);
$router->post('/consultations', [ConsultationController::class, 'store']);
$router->get('/login', [AuthController::class, 'login']);
$router->post('/login', [AuthController::class, 'handleLogin']);
$router->post('/logout', [AuthController::class, 'logout']);
$router->get('/dashboard', [DashboardController::class, 'index']);
$router->get('/session-demo', [DashboardController::class, 'sessionDemo']);

$router->dispatch($_SERVER['REQUEST_METHOD'], parse_url($_SERVER['REQUEST_URI'], PHP_URL_PATH));

```

Ghi chú: `session_set_cookie_params()` phải chạy trước `session_start()`. Nếu output ra HTML trước `session_start()`, PHP có thể không gửi được cookie/header.

Bước 4 - Tạo helper xử lý escape, redirect, flash, old/errors và timeout

```

<?php
// app/Support/helpers.php

function h(?string $value): string
{
    return htmlspecialchars($value ?? '', ENT_QUOTES, 'UTF-8');
}

function redirect(string $path): void
{
    header('Location: ' . $path);
    exit;
}

function flash_set(string $key, mixed $value): void
{
    $_SESSION['_flash'][$key] = $value;
}

function flash_get(string $key, mixed $default = null): mixed

```

```

{
    $value = $_SESSION['_flash'][$key] ?? $default;
    unset($_SESSION['_flash'][$key]);
    return $value;
}

function is_logged_in(): bool
{
    return isset($_SESSION['user_id']);
}

function require_login(): void
{
    if (!is_logged_in()) {
        flash_set('error', 'Vui lòng đăng nhập để truy cập dashboard.');
```

redirect('/login');

```

    }
}

function check_session_timeout(): void
{
    $idleLimit = 15 * 60; // 15 phút. Khi demo có thể đổi thành 60 giây.

    if (!isset($_SESSION['user_id'])) {
        return;
    }

    $last = $_SESSION['last_activity_at'] ?? time();
    if (time() - $last > $idleLimit) {
        logout_clean();
        session_start();
        flash_set('error', 'Phiên đăng nhập đã hết hạn. Vui lòng đăng nhập lại.');
```

redirect('/login');

```

    }

    $_SESSION['last_activity_at'] = time();
}

function check_session_context(): void
{
    if (!isset($_SESSION['user_id'])) {
        return;
    }

    $currentAgent = $_SERVER['HTTP_USER_AGENT'] ?? '';
    $savedAgent = $_SESSION['user_agent'] ?? '';

    if ($savedAgent !== '' && $savedAgent !== $currentAgent) {
        logout_clean();
        session_start();
        flash_set('error', 'Phiên có dấu hiệu bất thường. Vui lòng đăng nhập lại.');
```

redirect('/login');

```

    }
}

function logout_clean(): void
{
    $_SESSION = [];

```

```

if (ini_get('session.use_cookies')) {
    $params = session_get_cookie_params();
    setcookie(session_name(), "", time() - 42000,
        $params['path'],
        $params['domain'],
        $params['secure'],
        $params['httponly']
    );
}

session_destroy();
}

```

- h() dùng để tránh hiển thị trực tiếp dữ liệu người dùng nhập.
- flash_set/flash_get giúp thông báo chỉ hiện một lần sau redirect.
- check_session_timeout() giảm rủi ro phiên sống quá lâu.
- check_session_context() là biện pháp cơ bản, không tuyệt đối; dùng User-Agent để minh họa ý tưởng gắn ngữ cảnh phiên.

Bước 5 - Tạo Router và Response giống tinh thần Lab03

```

<?php
// app/Core/Router.php
namespace App\Core;

class Router
{
    private array $routes = [];

    public function get(string $path, array $handler): void
    {
        $this->add('GET', $path, $handler);
    }

    public function post(string $path, array $handler): void
    {
        $this->add('POST', $path, $handler);
    }

    private function add(string $method, string $path, array $handler): void
    {
        $this->routes[$path][$method] = $handler;
    }

    public function dispatch(string $method, string $path): void
    {
        if (!isset($this->routes[$path])) {
            http_response_code(404);
            view('errors/404');
            return;
        }

        if (!isset($this->routes[$path][$method])) {
            http_response_code(405);
            view('errors/405');
            return;
        }
    }
}

```

```

        [$class, $action] = $this->routes[$path][$method];
        (new $class())->$action();
    }
}

```

```

<?php
// Bổ sung vào app/Support/helpers.php
function view(string $view, array $data = []): void
{
    extract($data);
    require __DIR__ . '/../views/layout.php';
}

function view_path(string $view): string
{
    return __DIR__ . '/../views/' . $view . '.php';
}

```

Bước 6 - Tạo layout và CSS chung

```

<!-- views/layout.php -->
<!doctype html>
<html lang="vi">
<head>
    <meta charset="utf-8">
    <meta name="viewport" content="width=device-width, initial-scale=1">
    <title>Lab04 Secure Portal</title>
    <link rel="stylesheet" href="/assets/style.css">
</head>
<body>
<nav class="navbar">
    <strong>PHP Lab04 Secure Portal</strong>
    <a href="/">Home</a>
    <a href="/consultations">Consultations</a>
    <a href="/consultations/create">Create Lead</a>
    <a href="/dashboard">Dashboard</a>
    <a href="/login">Login</a>
    <form method="post" action="/logout" class="inline-form">
        <button type="submit" class="link-button">Logout</button>
    </form>
</nav>

<main class="container">
    <?php if ($success = flash_get('success')): ?>
        <div class="alert success"><?= h($success) ?></div>
    <?php endif; ?>

    <?php if ($error = flash_get('error')): ?>
        <div class="alert error"><?= h($error) ?></div>
    <?php endif; ?>

    <?php require view_path($view); ?>
</main>
</body>
</html>

```

```

/* public/assets/style.css */

```

```

* { box-sizing: border-box; }
body { margin: 0; font-family: Arial, sans-serif; background: #f8fafc; color: #0f172a; }
.navbar { display: flex; gap: 18px; align-items: center; padding: 18px 32px; background: #0f172a; color: white; }
.navbar a, .link-button { color: #e2e8f0; text-decoration: none; background: none; border: 0; cursor: pointer; font: inherit; }
.container { max-width: 1080px; margin: 32px auto; padding: 0 20px; }
.card { background: white; border: 1px solid #e2e8f0; border-radius: 16px; padding: 24px; margin-bottom: 18px; box-shadow: 0 8px 24px rgba(15, 23, 42, .06); }
.grid { display: grid; grid-template-columns: repeat(2, minmax(0, 1fr)); gap: 16px; }
.form-group { margin-bottom: 16px; }
label { display: block; font-weight: 700; margin-bottom: 6px; }
input, select, textarea { width: 100%; padding: 12px; border: 1px solid #cbd5e1; border-radius: 10px; font-size: 15px; }
textarea { min-height: 120px; }
.error-text { color: #dc2626; font-size: 14px; margin-top: 4px; }
.alert { padding: 14px 16px; border-radius: 12px; margin-bottom: 16px; font-weight: 700; }
.alert.success { background: #dcfce7; color: #166534; }
.alert.error { background: #fee2e2; color: #991b1b; }
.btn { padding: 12px 16px; border: 0; border-radius: 10px; cursor: pointer; font-weight: 700; }
.btn.primary { background: #2563eb; color: white; }
.btn.secondary { background: #64748b; color: white; }
table { width: 100%; border-collapse: collapse; background: white; }
table th, table td { border: 1px solid #e2e8f0; padding: 12px; text-align: left; }
table th { background: #f1f5f9; }
.honeypot { display: none; }
.inline-form { display: inline; }

```

Bước 7 - Tạo HomeController và trang tổng quan

```

<?php
// app/Controllers/HomeController.php
namespace App\Controllers;

class HomeController
{
    public function index(): void
    {
        view('home', ['view' => 'home']);
    }
}

```

```

<!-- views/home.php -->
<h1>Lab04 - Secure Forms & Session Login Flow</h1>
<p>Tuần 4 + Tuần 5: xử lý form nghiệp vụ và login/session flow an toàn hơn.</p>

<div class="grid">
    <div class="card"><h2>Secure Form</h2><p>GET/POST, đọc input an toàn, escape output.</p></div>
    <div class="card"><h2>Validation + PRG</h2><p>Hiển thị lỗi, giữ dữ liệu cũ, redirect để tránh submit trùng.</p></div>
    <div class="card"><h2>Anti-spam</h2><p>Honeypot và rate limit đơn giản.</p></div>
    <div class="card"><h2>Login/Session</h2><p>Cookie flags, regenerate, timeout, logout sạch.</p></div>
</div>

```

Bước 8 - Tạo form đăng ký tư vấn

```

<?php
// app/Controllers/ConsultationController.php

```

```

namespace App\Controllers;

class ConsultationController
{
    private array $allowedCourses = ['web', 'design', 'marketing'];

    public function create(): void
    {
        $old = flash_get('old', []);
        $errors = flash_get('errors', []);

        view('consultations/create', [
            'view' => 'consultations/create',
            'old' => $old,
            'errors' => $errors,
            'allowedCourses' => $this->allowedCourses,
        ]);
    }
}

```

```

<!-- views/consultations/create.php -->
<h1>Form đăng ký tư vấn</h1>
<p>Form này submit đến <strong>POST /consultations</strong>.</p>

<?php if (!empty($errors['_global'])): ?>
    <div class="alert error"><?= h($errors['_global']) ?></div>
<?php endif; ?>

<form method="post" action="/consultations" class="card">
    <div class="form-group">
        <label>Họ tên</label>
        <input name="name" value="<?= h($old['name']) ?? '' ?>">
        <?php if (!empty($errors['name'])): ?><div class="error-text"><?= h($errors['name']) ?></div><?php endif; ?>
    </div>

    <div class="form-group">
        <label>Email</label>
        <input name="email" value="<?= h($old['email']) ?? '' ?>">
        <?php if (!empty($errors['email'])): ?><div class="error-text"><?= h($errors['email']) ?></div><?php endif; ?>
    </div>

    <div class="form-group">
        <label>Số điện thoại</label>
        <input name="phone" value="<?= h($old['phone']) ?? '' ?>">
        <?php if (!empty($errors['phone'])): ?><div class="error-text"><?= h($errors['phone']) ?></div><?php endif;
?>
    </div>

    <div class="form-group">
        <label>Khóa học quan tâm</label>
        <select name="course">
            <option value="">-- Chọn khóa học --</option>
            <option value="web" <?= (($old['course'] ?? '') === 'web') ? 'selected' : '' ?>>Web Development</option>
            <option value="design" <?= (($old['course'] ?? '') === 'design') ? 'selected' : '' ?>>Digital Design</option>
            <option value="marketing" <?= (($old['course'] ?? '') === 'marketing') ? 'selected' : '' ?>>Digital
Marketing</option>
        </select>

```

```

        <?php if (!empty($errors['course'])): ?><div class="error-text"><?= h($errors['course']) ?></div><?php endif;
?>
    </div>

    <div class="form-group">
        <label>Nội dung cần tư vấn</label>
        <textarea name="message"><?= h($old['message']) ?? '' ?></textarea>
        <?php if (!empty($errors['message'])): ?><div class="error-text"><?= h($errors['message']) ?></div><?php
endif; ?>
    </div>

    <div class="honeypot">
        <label>Website</label>
        <input name="website" tabindex="-1" autocomplete="off">
    </div>

    <button class="btn primary" type="submit">Gửi đăng ký</button>
    <a class="btn secondary" href="/consultations">Quay lại</a>
</form>

```

Bước 9 - Đọc input POST an toàn và validate server-side

```

// Thêm vào ConsultationController.php
public function store(): void
{
    $data = [
        'name' => trim($_POST['name']) ?? '',
        'email' => trim($_POST['email']) ?? '',
        'phone' => trim($_POST['phone']) ?? '',
        'course' => trim($_POST['course']) ?? '',
        'message' => trim($_POST['message']) ?? '',
        'website' => trim($_POST['website']) ?? '', // honeypot
    ];

    $errors = $this->validate($data);

    if (!empty($errors)) {
        flash_set('errors', $errors);
        flash_set('old', [
            'name' => $data['name'],
            'email' => $data['email'],
            'phone' => $data['phone'],
            'course' => $data['course'],
            'message' => $data['message'],
        ]);
        redirect('/consultations/create');
    }

    $this->saveConsultation($data);
    $_SESSION['last_consultation_submit_at'] = time();

    flash_set('success', 'Đăng ký tư vấn thành công. PRG đã redirect về trang danh sách.');
```

```

    redirect('/consultations');
}

private function validate(array $data): array
{
    $errors = [];

```

```

if ($data['website'] !== '') {
    $errors['_global'] = 'Yêu cầu bị từ chối do phát hiện hành vi giống bot.';
}

$lastSubmit = $_SESSION['last_consultation_submit_at'] ?? 0;
if ($lastSubmit && time() - $lastSubmit < 5) {
    $errors['_global'] = 'Bạn gửi quá nhanh. Vui lòng thử lại sau vài giây.';
}

if ($data['name'] === '') {
    $errors['name'] = 'Vui lòng nhập họ tên.';
} elseif (mb_strlen($data['name']) < 2) {
    $errors['name'] = 'Họ tên phải có ít nhất 2 ký tự.';
}

if ($data['email'] === '') {
    $errors['email'] = 'Vui lòng nhập email.';
} elseif (!filter_var($data['email'], FILTER_VALIDATE_EMAIL)) {
    $errors['email'] = 'Email không đúng định dạng.';
}

if ($data['phone'] === '') {
    $errors['phone'] = 'Vui lòng nhập số điện thoại.';
} elseif (!preg_match('/^[0-9+\-\s]{9,15}$/', $data['phone'])) {
    $errors['phone'] = 'Số điện thoại chỉ gồm số, khoảng trắng, + hoặc -, dài 9-15 ký tự.';
}

if ($data['course'] === '' || !in_array($data['course'], $this->allowedCourses, true)) {
    $errors['course'] = 'Vui lòng chọn khóa học hợp lệ.';
}

if ($data['message'] !== '' && mb_strlen($data['message']) > 300) {
    $errors['message'] = 'Nội dung không được vượt quá 300 ký tự.';
}

return $errors;
}

```

Ghi chú: Dù form có `required` hoặc `type=email` ở HTML, server-side validation vẫn bắt buộc vì user có thể sửa HTML, tắt JavaScript hoặc gửi request thủ công bằng tool khác.

Bước 10 - Lưu lead vào JSON và hiển thị danh sách

```

// Thêm vào ConsultationController.php
public function index(): void
{
    view('consultations/index', [
        'view' => 'consultations/index',
        'items' => $this->loadConsultations(),
    ]);
}

private function storageFile(): string
{
    return __DIR__ . '/../../storage/consultations.json';
}

private function loadConsultations(): array
{

```

```

$json = file_get_contents($this->storageFile());
return json_decode($json, true) ?: [];
}

private function saveConsultation(array $data): void
{
    $items = $this->loadConsultations();
    $items[] = [
        'id' => 'L' . str_pad((string) (count($items) + 1), 3, '0', STR_PAD_LEFT),
        'name' => $data['name'],
        'email' => $data['email'],
        'phone' => $data['phone'],
        'course' => $data['course'],
        'message' => $data['message'],
        'created_at' => date('Y-m-d H:i:s'),
    ];

    file_put_contents($this->storageFile(), json_encode($items, JSON_PRETTY_PRINT | JSON_UNESCAPED_UNICODE));
}

```

```

<!-- views/consultations/index.php -->
<h1>Danh sách lead tư vấn</h1>
<p><a class="btn primary" href="/consultations/create">Tạo lead mới</a></p>

<table class="table">
    <thead>
        <tr>
            <th>ID</th><th>Họ tên</th><th>Email</th><th>Phone</th><th>Course</th><th>Created at</th>
        </tr>
    </thead>
    <tbody>
        <?php foreach ($items as $item): ?>
            <tr>
                <td><?= h($item['id']) ?></td>
                <td><?= h($item['name']) ?></td>
                <td><?= h($item['email']) ?></td>
                <td><?= h($item['phone']) ?></td>
                <td><?= h($item['course']) ?></td>
                <td><?= h($item['created_at']) ?></td>
            </tr>
        <?php endforeach; ?>
    </tbody>
</table>

```

Bước 11 - Tạo login form và user demo

```

<?php
// app/Controllers/AuthController.php
namespace App\Controllers;

class AuthController
{
    private array $users;

    public function __construct()
    {
        $this->users = [
            'student@example.com' => [

```

```

        'id' => 1,
        'name' => 'Nguyễn Văn Student',
        'role' => 'student',
        'password_hash' => password_hash('123456', PASSWORD_DEFAULT),
    ],
];
}

public function login(): void
{
    if (is_logged_in()) {
        redirect('/dashboard');
    }

    view('auth/login', [
        'view' => 'auth/login',
        'old' => flash_get('old', []),
        'errors' => flash_get('errors', []),
    ]);
}
}

```

```

<!-- views/auth/login.php -->
<h1>Đăng nhập hệ thống</h1>
<p>Tài khoản demo: <strong>student@example.com</strong> / <strong>123456</strong></p>

<form method="post" action="/login" class="card">
    <div class="form-group">
        <label>Email</label>
        <input name="email" value="<?= h($old['email'] ?? '') ?>">
        <?php if (!empty($errors['email'])): ?><div class="error-text"><?= h($errors['email']) ?></div><?php endif; ?>
    </div>

    <div class="form-group">
        <label>Password</label>
        <input type="password" name="password">
        <?php if (!empty($errors['password'])): ?><div class="error-text"><?= h($errors['password']) ?></div><?php
endif; ?>
    </div>

    <div class="form-group">
        <label><input type="checkbox" name="remember_me" value="1"> Remember me</label>
        <small>Lab04 chỉ giới thiệu rủi ro. Không lưu password trong cookie.</small>
    </div>

    <button class="btn primary" type="submit">Login</button>
</form>

```

Bước 12 - Xử lý POST /login: validate, verify password, regenerate session

```

// Thêm vào AuthController.php
public function handleLogin(): void
{
    $email = trim($_POST['email'] ?? '');
    $password = $_POST['password'] ?? '';
    $remember = ($_POST['remember_me'] ?? '') === '1';

    $errors = [];

```

```

if ($email === '') {
    $errors['email'] = 'Vui lòng nhập email.';
} elseif (!filter_var($email, FILTER_VALIDATE_EMAIL)) {
    $errors['email'] = 'Email không đúng định dạng.';
}

if ($password === '') {
    $errors['password'] = 'Vui lòng nhập password.';
}

$user = $this->users[$email] ?? null;
if (empty($errors) && (!$user || !password_verify($password, $user['password_hash']))) {
    $errors['password'] = 'Email hoặc password không đúng.';
}

if (!empty($errors)) {
    flash_set('errors', $errors);
    flash_set('old', ['email' => $email]);
    redirect('/login');
}

session_regenerate_id(true);

$_SESSION['user_id'] = $user['id'];
$_SESSION['user_name'] = $user['name'];
$_SESSION['role'] = $user['role'];
$_SESSION['login_at'] = time();
$_SESSION['last_activity_at'] = time();
$_SESSION['user_agent'] = $_SERVER['HTTP_USER_AGENT'] ?? '';

if ($remember) {
    flash_set('success', 'Đăng nhập thành công. Remember me cần token riêng; Lab04 không lưu password trong cookie.');
```

```

    } else {
        flash_set('success', 'Đăng nhập thành công. Session ID đã được regenerate.');
```

```

    }

    redirect('/dashboard');
}

```

Ghi chú: Điểm quan trọng nhất của login flow: sau khi xác thực thành công, phải gọi `session_regenerate_id(true)`. Trước login, session chưa đáng tin; sau login, phiên đã đại diện cho user thật.

Bước 13 - Tạo dashboard yêu cầu đăng nhập

```

<?php
// app/Controllers/DashboardController.php
namespace App\Controllers;

class DashboardController
{
    public function index(): void
    {
        require_login();
        view('dashboard', ['view' => 'dashboard']);
    }

    public function sessionDemo(): void

```

```
{
    require_login();
    header('Content-Type: application/json; charset=utf-8');
    echo json_encode([
        'user_id' => $_SESSION['user_id'] ?? null,
        'user_name' => $_SESSION['user_name'] ?? null,
        'role' => $_SESSION['role'] ?? null,
        'login_at' => date('Y-m-d H:i:s', $_SESSION['login_at'] ?? time()),
        'last_activity_at' => date('Y-m-d H:i:s', $_SESSION['last_activity_at'] ?? time()),
        'session_name' => session_name(),
    ], JSON_PRETTY_PRINT | JSON_UNESCAPED_UNICODE);
}
}
```

```
<!-- views/dashboard.php -->
<h1>Dashboard</h1>
<div class="card">
    <h2>Xin chào, <?= h($_SESSION['user_name'] ?? '') ?></h2>
    <p>Role: <strong><?= h($_SESSION['role'] ?? '') ?></strong></p>
    <p>Login at: <?= h(date('Y-m-d H:i:s', $_SESSION['login_at'] ?? time())) ?></p>
    <p>Last activity: <?= h(date('Y-m-d H:i:s', $_SESSION['last_activity_at'] ?? time())) ?></p>
    <p><a class="btn secondary" href="/session-demo">Xem session debug JSON</a></p>
</div>
```

Bước 14 - Logout sạch bằng POST /logout

```
// Thêm vào AuthController.php
public function logout(): void
{
    logout_clean();

    // Tạo session mới chỉ để chứa flash sau logout
    session_start();
    flash_set('success', 'Đăng xuất thành công. Session cũ đã được xóa.');
```

```
    redirect('/login');
}
```

- Logout sạch không chỉ unset user_id.
- Cần xóa toàn bộ \$_SESSION, destroy session và xóa cookie phiên.
- Nếu có remember me thật, logout cũng phải xóa/thu hồi remember token.

Bước 15 - Tạo view 404 và 405

```
<!-- views/errors/404.php -->
<h1>404 Not Found</h1>
<p>URL bạn truy cập không tồn tại.</p>
<a href="/">Về trang chủ</a>

<!-- views/errors/405.php -->
<h1>405 Method Not Allowed</h1>
<p>URL có tồn tại nhưng HTTP method không phù hợp.</p>
<a href="/">Về trang chủ</a>
```

Bước 16 - Chạy project

```
php -S localhost:8000 -t public
```

- Mở `http://localhost:8000/`.
- Truy cập `/consultations/create` để test form.
- Truy cập `/login` để test đăng nhập.
- Truy cập `/dashboard` khi chưa đăng nhập để kiểm tra redirect về login.

8) Test cases bắt buộc

Nhóm test	Thao tác	Kết quả mong đợi
GET/POST	Mở <code>/consultations/create</code> rồi submit form	POST <code>/consultations</code> được xử lý bởi <code>ConsultationController@store</code>
Validation	Bỏ trống name/email/phone/course	Redirect về form, hiển thị lỗi đúng field, dữ liệu cũ còn lại
Email format	Nhập email <code>abc@</code>	Báo Email không đúng định dạng
Phone pattern	Nhập phone <code>abc123</code>	Báo lỗi số điện thoại
In-list	Dùng DevTools sửa course thành <code>hacking</code>	Bị chặn vì không nằm trong <code>allowedCourses</code>
Honeypot	Dùng DevTools điền field <code>website</code>	Bị chặn với lỗi hành vi giống bot
Rate limit	Submit thành công rồi gửi lại trong 5 giây	Bị chặn gửi quá nhanh
PRG	Submit form hợp lệ rồi refresh <code>/consultations</code>	Không tạo lead trùng
Login sai	Nhập password sai	Redirect về login, flash lỗi đúng
Login đúng	<code>student@example.com</code> / <code>123456</code>	Regenerate session, redirect dashboard, flash success
Auth guard	Mở <code>/dashboard</code> khi chưa login	Redirect về <code>/login</code>
Logout sạch	Click logout POST	Xóa session, redirect login, không vào được dashboard
Timeout	Đổi <code>idleLimit</code> thành 60 giây, login rồi chờ quá thời gian	Bị redirect login và báo phiên hết hạn
Cookie flags	Mở DevTools > Application > Cookies	Thấy <code>LAB04SESSID</code> có <code>HttpOnly</code> , <code>SameSite=Lax</code> ; Secure bật khi chạy HTTPS